

MITRE ATT&CK Overview

MITRE ATT&CK (**Adversarial Tactics, Techniques, and Common Knowledge**) is a globally accessible knowledge base of real-world adversary behavior, maintained by MITRE Corporation since 2013. Where the Cyber Kill Chain gives you a 7-stage linear story, ATT&CK gives you the detailed, non-linear, constantly-updated encyclopedia of *how* attackers actually operate — based on observed, documented intrusions, not theory.

Think of it this way: **Kill Chain = the chapters. ATT&CK = every paragraph, sentence, and footnote inside each chapter, sourced from real incidents.**

Core Structure

ATT&CK is organized into a matrix with three main building blocks:

1. Tactics (the "Why")

The adversary's **goal** at a given stage — there are 14 tactics in the Enterprise matrix:

Tactic	Adversary's Goal
Reconnaissance	Gathering info to plan attack
Resource Development	Building attack infrastructure
Initial Access	Getting into the network
Execution	Running malicious code
Persistence	Maintaining foothold
Privilege Escalation	Gaining higher-level permissions
Defense Evasion	Avoiding detection
Credential Access	Stealing account credentials
Discovery	Understanding the environment
Lateral Movement	Moving through the network
Collection	Gathering data of interest
Command and Control	Communicating with compromised systems
Exfiltration	Stealing data out
Impact	Disrupting, destroying, or manipulating

2. Techniques (the "How")

Each tactic has multiple techniques — the *specific method* used to achieve that goal.

Example under Initial Access (TA0001):

- T1566 — Phishing
- T1190 — Exploit Public-Facing Application
- T1078 — Valid Accounts

3. Sub-techniques (the "How, more specifically")

Techniques often break down further.

Example — T1566 Phishing has sub-techniques:

- T1566.001 — Spearphishing Attachment
- T1566.002 — Spearphishing Link
- T1566.003 — Spearphishing via Service

Each technique/sub-technique page includes:

- **Description** of how it's used
- **Procedure examples** — real APT groups that used it, and how
- **Mitigations** — defensive controls to prevent it
- **Detection** — what log sources/analytics catch it
- **Data Sources** — what telemetry (process creation, network traffic, etc.) reveals it

The Different ATT&CK Matrices

ATT&CK isn't one-size-fits-all — there are separate matrices for different environments:

- **Enterprise** — Windows, Linux, macOS, cloud, network, containers (the main one you'll use most)
 - **Mobile** — Android/iOS-specific adversary behavior
 - **ICS** — Industrial Control Systems (SCADA, PLCs — think Stuxnet-style attacks)
-

Worked Example: Mapping a Real Attack Technique

Let's take something concrete — **credential dumping using Mimikatz**, which you'll run into constantly in AD pentesting:

ATT&CK Field	Value
Tactic	Credential Access (TA0006)
Technique	OS Credential Dumping (T1003)
Sub-technique	LSASS Memory (T1003.001)
Procedure	Mimikatz extracts plaintext credentials/hashes from LSASS process memory
Used by	APT29, FIN6, many ransomware groups
Detection	Monitor for unusual access to <code>lsass.exe</code> , Sysmon Event ID 10 (ProcessAccess)
Mitigation	Enable Credential Guard, restrict LSASS access, LAPS for local admin passwords

This is exactly the kind of mapping a SOC analyst does when writing up a detection rule or an incident report — instead of saying "attacker used Mimikatz," you tag it as **T1003.001**, which instantly tells anyone reading the report the tactic, technique, and expected detection/mitigation strategy without extra explanation.

Real-World APT Group Profiles (ATT&CK tracks these too)

ATT&CK maintains profiles of known threat actor groups, mapping their historical TTPs:

APT29 (Cozy Bear) — linked to the SolarWinds attack:

- Initial Access: T1195.002 (Supply Chain Compromise — Software Supply Chain)
- Defense Evasion: T1027 (Obfuscated Files or Information)
- C2: T1071.001 (Application Layer Protocol — Web Protocols, mimicking legit traffic)

Lazarus Group — North Korean state-sponsored, behind the WannaCry ransomware and Sony Pictures hack:

- Initial Access: T1566.001 (Spearphishing Attachment)
- Impact: T1486 (Data Encrypted for Impact)

This lets defenders build **threat-actor-specific detection strategies** — if your threat intel says APT29 is targeting your sector, you can pull their exact ATT&CK technique list and check your SIEM has detections for each one.

How ATT&CK Is Actually Used in the Industry

1. SOC / Detection Engineering

Analysts map SIEM alert rules directly to technique IDs. Splunk, Sentinel, and most modern SIEMs support "ATT&CK Navigator" heatmaps showing which techniques you *can* detect vs. gaps in coverage.

2. Purple Teaming

Red team simulates specific ATT&CK techniques (e.g., T1055 Process Injection), blue team checks if their tools caught it — this closes detection gaps systematically instead of randomly.

3. Threat Intelligence Reports

Vendor reports (Mandiant, CrowdStrike, Microsoft) tag every observed behavior with ATT&CK IDs, making cross-report comparison standardized.

4. Pentest/Red Team Reporting

Instead of writing "we escalated privileges using a kernel exploit," professional reports tag it: **T1068 — Exploitation for Privilege Escalation** — this is now a standard expectation in mature pentest reports and something you should start doing in your own VulnHub writeups.

5. Gap Analysis

Organizations use the **ATT&CK Navigator** (a free web tool: mitre-attack.github.io/attack-navigator) to build a heatmap of their entire environment's detection coverage — red for "no visibility," green for "fully covered" — technique by technique.

ATT&CK vs. Cyber Kill Chain — Key Differences

	Cyber Kill Chain	MITRE ATT&CK
Structure	Linear, 7 fixed stages	Non-linear, techniques can be used in any order/repeated

	Cyber Kill Chain	MITRE ATT&CK
Granularity	High-level phases	Hundreds of specific, documented techniques
Source	Conceptual model	Built from real observed intrusions
Best for	Teaching the overall attack lifecycle	Building actual detections, threat intel, red/purple teaming
Coverage	Malware-centric, perimeter-focused	Covers cloud, insider threats, living-off-the-land, containers

They're complementary, not competing — many organizations map Kill Chain stages to ATT&CK tactics as a bridge between the "big picture" and "technical detail."